Security Assessment and Vulnerability Analysis Using Open-Source Tools

Submitted By : Aditya Mehta

Domain : VAPT

Prepared at : 13th March, 2026

Summary :

- Cybersecurity assessments are essential for identifying vulnerabilities in systems before they can be exploited by attackers.
- Organizations regularly conduct Vulnerability Assessment and Penetration Testing (VAPT) to detect weaknesses, evaluate security risks, and implement appropriate mitigation strategies.
- This project demonstrates the process of performing a basic security assessment using open-source tools in a controlled lab environment.
- The testing environment consisted of an attacker machine running **Kali Linux** and a vulnerable target machine **Metasploitable,** both hosted in Oracle VM VirtualBox.
- Various open-source tools were used during the assessment process.
- **Nmap** was used to identify open ports and running services, **Nikto** was used to detect web server vulnerabilities, and **OpenVAS** was used to perform vulnerability analysis.

- The findings from the scans were analyzed using the Common Vulnerability Scoring System (CVSS) provided by the National Vulnerability Database.
- Vulnerabilities were categorized into risk levels based on their severity.
- The results highlight the importance of regular vulnerability assessments in improving system security and reducing potential attack surfaces.

Introduction :

- With the rapid growth of digital technologies, organizations rely heavily on computer networks and online services.
- However, these systems are frequently targeted by cyber attackers attempting to exploit vulnerabilities.
- A security assessment is the process of identifying weaknesses in a system, network, or application.
- These weaknesses may exist due to outdated software, insecure configurations, open ports, or vulnerable applications.
- Security professionals use Vulnerability Assessment and Penetration Testing (VAPT) to evaluate the security posture of systems.
- Vulnerability assessment focuses on identifying weaknesses, while penetration testing attempts to exploit these weaknesses to determine their real-world impact.
- In this project, a controlled lab environment was created using virtualization technology.

- The attacker machine used **Kali Linux**, which is widely used for penetration testing, while the target machine used **Metasploitable**, an intentionally vulnerable system designed for security training.
- By performing scanning and vulnerability analysis using open-source tools, the project demonstrates how security professionals identify vulnerabilities and prioritize risks.

Understanding Security Assessment :

- A security assessment is the systematic evaluation of an organization's information systems to determine their security level.
- It helps identify vulnerabilities, misconfigurations, and potential attack vectors.
- Security assessments are typically guided by industry frameworks such as those developed by the **National Institute of Standards and Technology**.

Types of Security Testing :

— **Vulnerability Assessment :**

- Vulnerability assessment focuses on identifying security weaknesses without actively exploiting them.
- Tools like **OpenVAS** are commonly used to detect vulnerabilities, assign severity scores, and provide remediation recommendations.

— **Penetration Testing :**

- Penetration testing simulates real-world attacks to determine whether vulnerabilities can be exploited.
- Security professionals use tools such as **Metasploit Framework** and **Nmap** to test system defenses.

— **Compliance Testing :**

- Compliance testing verifies whether systems follow industry security standards.
- Organizations often use security checklists such as CIS Benchmarks to ensure systems are configured securely.

VAPT Methodology :

- The process of vulnerability assessment and penetration testing follows a structured methodology.

— **Planning Phase :**

- In this phase, the scope and objectives of the assessment are defined.
- Security professionals identify target systems, testing boundaries, and rules of engagement.
- Tools such as **Dradis** Community Edition help organize project information.

— **Discovery Phase :**

- During this phase, information about the target system is gathered.
- Security testers identify open ports, services, and applications using tools such as **Nmap** and **OWASP ZAP**.

— **Attack Phase :**

- In this phase, vulnerabilities identified during discovery are tested for exploitability.
- Tools like **Metasploit Framework** allow security professionals to simulate attacks.

— **Reporting Phase :**

- The final phase involves documenting findings, assigning risk levels, and providing remediation recommendations.
- Reporting tools such as **Pentest-Tools** can assist in generating professional reports.

Security Standards and Compliance :

- Organizations must follow internationally recognized security standards to protect sensitive information.
- One widely adopted standard is **ISO/IEC 27001**, which provides guidelines for establishing an Information Security Management System.
- Another important regulation is the **General Data Protection Regulation**, which focuses on protecting personal data and ensuring privacy.
- Healthcare organizations follow the **Health Insurance Portability and Accountability Act,** which establishes security requirements for protecting medical information.
- Security testers also reference the **OWASP Top 10**, which lists the most critical web application vulnerabilities.

Risk Assessment Basics :

- Risk assessment helps prioritize vulnerabilities based on their severity and potential impact.
- Security professionals use the **Common Vulnerability Scoring System (CVSS)** to measure vulnerability severity.
- CVSS scores are available through the **National Vulnerability Database.**

Risk Matrix :

CVSS Score	Risk Level
0 – 3.9	Low
4 – 6.9	Medium
7 -10	High

- Using this classification, organizations can focus on addressing high-risk vulnerabilities first.

Common Vulnerabilities :

- Security assessments often reveal several types of vulnerabilities.

— **Network Vulnerabilities :**

  - Network vulnerabilities may occur due to misconfigured services or open ports. Tools such as **Nmap** help identify these weaknesses.
  - Examples include : Open FTP services, Weak authentication mechanisms, Exposed SMB services.

— **Web Application Vulnerabilities :**

- Web applications are common targets for attackers.
- Vulnerabilities such as **SQL injection and Cross-Site Scripting (XSS)** are frequently discovered.
- Practice environments such as **OWASP Juice Shop, Metasploitable, and VulnHub** allow security professionals to learn how to identify these vulnerabilities.

Documentation Fundamentals :

- Proper documentation is an essential part of cybersecurity assessments.
- It ensures that vulnerabilities are recorded clearly and remediation steps are communicated effectively.
- Security professionals often use tools such as **Dradis Community Edition** and **CherryTree** to record findings.
- Spreadsheets such as **Microsoft Excel** are also used to track vulnerabilities.

Practical Implementation :

Lab Environment Setup :

- The testing environment was created using **VirtualBox**. Two virtual machines were configured:

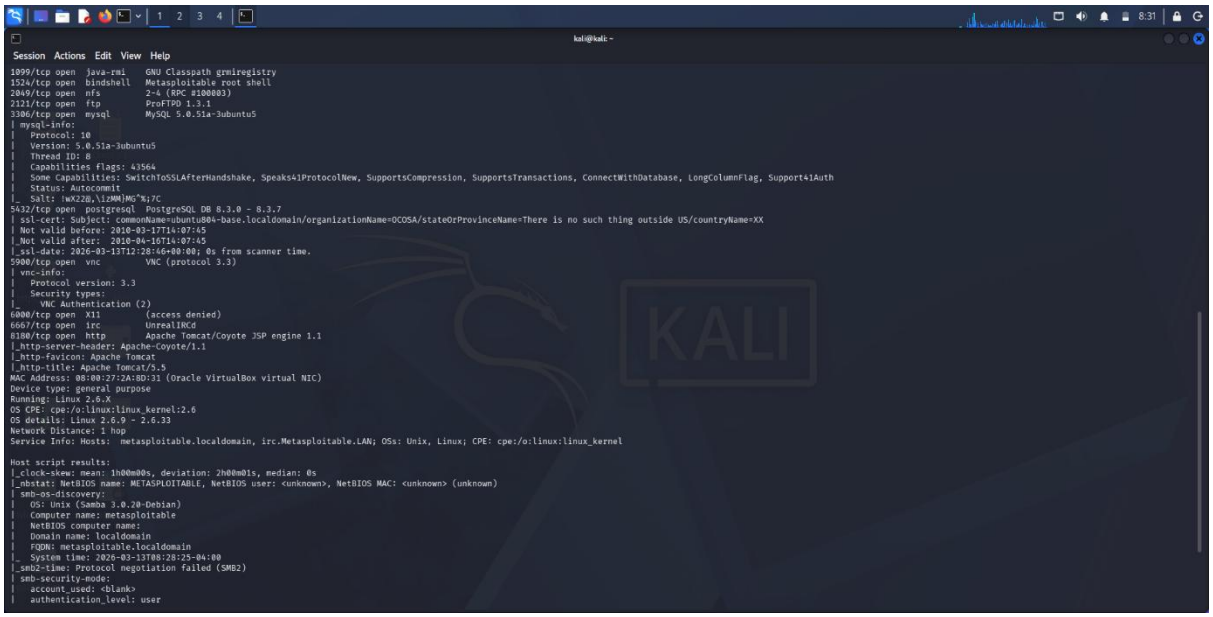
Machine	Role
Kali Linux	Attacker
Metasploitable	Vulnerable target

- Both machines were connected using a host-only network adapter.

Vulnerability Scanning :

— Network Scan :

- Network scanning was performed using **Nmap.**
- **Example command :** nmap -sV -A <target-ip>
- This scan identified open ports and services on the target machine.



```
|_  Salt: !wX22@,\i2MM]MG^%;7C
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
|_ssl-date: 2026-03-13T12:28:46+00:00; 0s from scanner time.
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_    VNC Authentication (2)
6000/tcp open  X11         (access denied)
6667/tcp open  irc         UnrealIRCd
8180/tcp open  http        Apache Tomcat/Coyote JSP engine 1.1
|_http-server-header: Apache-Coyote/1.1
|_http-favicon: Apache Tomcat
|_http-title: Apache Tomcat/5.5
MAC Address: 08:00:27:2A:8D:31 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 2.6.X
OS CPE: cpe:/o:linux:linux_kernel:2.6
OS details: Linux 2.6.9 - 2.6.33
Network Distance: 1 hop
Service Info: Hosts:  metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
|_clock-skew: mean: 1h00m00s, deviation: 2h00m01s, median: 0s
|_nbstat: NetBIOS name: METASPLOITABLE, NetBIOS user: <unknown>, NetBIOS MAC: <unknown> (unknown)
| smb-os-discovery:
|   OS: Unix (Samba 3.0.20-Debian)
|   Computer name: metasploitable
|   NetBIOS computer name:
|   Domain name: localdomain
|   FQDN: metasploitable.localdomain
|_  System time: 2026-03-13T08:28:25-04:00
|_smb2-time: Protocol negotiation failed (SMB2)
| smb-security-mode:
|   account_used: <blank>
|   authentication_level: user
|   challenge_response: supported
|_  message_signing: disabled (dangerous, but default)

TRACEROUTE
HOP RTT      ADDRESS
1   25.65 ms 192.168.56.101

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 52.02 seconds

┌──(kali㉿kali)-[~]
└─$
```

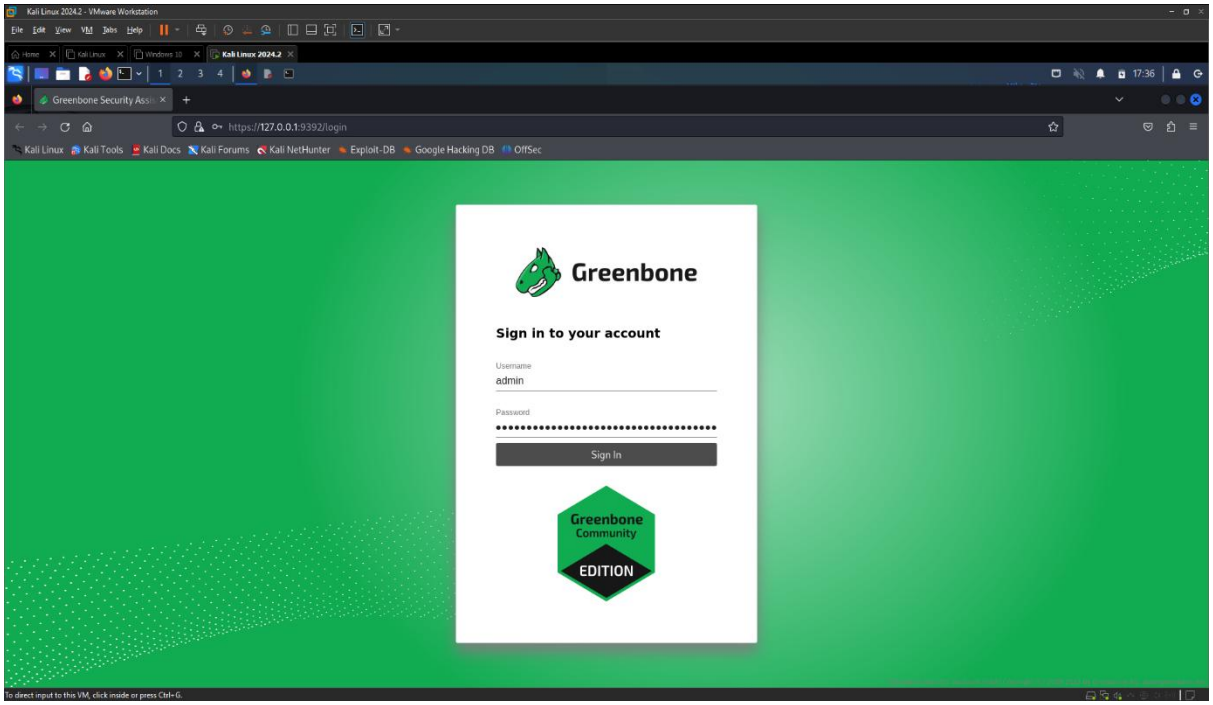
— Web Server Scan :

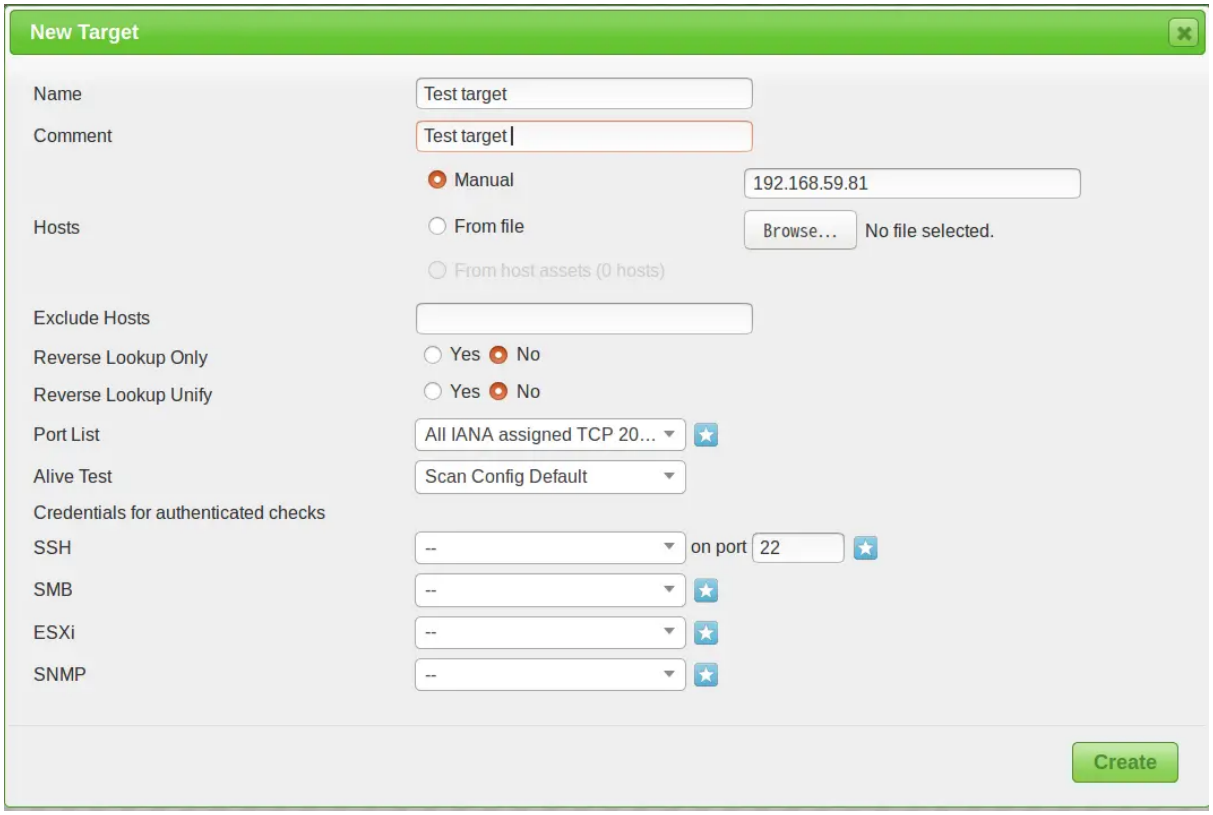
- Web vulnerability scanning was performed using Nikto.
  - ➢ Nikto -h http://<target-ip>
- The scan revealed several issues such as outdated server software and insecure configurations.

```
TRACEROUTE
HOP RTT      ADDRESS
1   25.65 ms 192.168.56.101

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 52.02 seconds

┌──(kali㉿kali)-[~]
└─$ nikto -h http://192.168.56.101
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.56.101
+ Target Hostname:    192.168.56.101
+ Target Port:        80
+ Start Time:         2026-03-13 08:34:07 (GMT-4)
---------------------------------------------------------------------------
+ Server: Apache/2.2.8 (Ubuntu) DAV/2
+ /: Retrieved x-powered-by header: PHP/5.2.4-2ubuntu5.10.
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mis
sing-content-type-header/
+ /index: Uncommon header 'tcn' found, with contents: list.
+ /index: Apache mod_negotiation is enabled with MultiViews, which allows attackers to easily brute force file names. The following alternatives for 'index' were found: index.php. See: http://www.wisec.it/sectou.php?id=4698ebdc59d15,ht
tps://exchange.xforce.ibmcloud.com/vulnerabilities/8275
+ Apache/2.2.8 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ /: Web Server returns a valid response with junk HTTP methods which may cause false positives.
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /phpinfo.php: Output from the phpinfo() function was found.
+ /?=PHPB8B5F2A0-3C92-11d3-A3A9-4C7B08C10000: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F36-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F34-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /?=PHPE9568F35-D428-11d2-A769-00AA001ACF42: PHP reveals potentially sensitive information via certain HTTP requests that contain specific QUERY strings. See: OSVDB-12184
+ /phpMyAdmin/changelog.php: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/ChangeLog: Server may leak inodes via ETags, header found with file /phpMyAdmin/ChangeLog, inode: 92462, size: 40540, mtime: Tue Dec  9 12:24:00 2008. See: http://cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2003-1418
+ /phpMyAdmin/ChangeLog: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /test/: Directory indexing found.
+ /test/: This might be interesting.
+ /phpinfo.php: PHP is installed, and a test script which runs phpinfo() was found. This gives a lot of system information. See: CWE-552
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ /phpMyAdmin/: phpMyAdmin directory found.
+ /phpMyAdmin/Documentation.html: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts.
+ /phpMyAdmin/README: phpMyAdmin is for managing MySQL databases, and should be protected or limited to authorized hosts. See: https://typo3.org/
+ /#wp-config.php#: #wp-config.php# file found. This file contains the credentials.
+ 8911 requests: 1 error(s) and 25 item(s) reported on remote host
+ End Time:           2026-03-13 08:46:15 (GMT-4) (728 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested

┌──(kali㉿kali)-[~]
└─$
```

— Vulnerability Scan :

- A vulnerability scan was conducted using **OpenVAS** to detect known vulnerabilities.





Risk Assessment Results :

Vulnerability	CVE	CVSS	Risk
Apache Outdated Version	CVE-2011-3192	7.5	Medium
phpMyAdmin Exposure	CVE-2009-1151	7.5	Medium
Missing Security Header	N/A	4.3	Low

Remediation Recommendations :

- Updating outdated software.
- Disabling unnecessary services.
- Implementing HTTP security headers.
- Restricting database administration access.

- Removing default configuration files.

Key Learnings :

1. Learned how to perform network reconnaissance using **Nmap** to identify open ports and services.
2. Understood how web vulnerability scanners like **Nikto** detect insecure server configurations.
3. Gained practical knowledge of vulnerability scanning using **OpenVAS.**
4. Learned how to analyze vulnerabilities using CVSS scores from the **National Vulnerability Database**.
5. Developed understanding of the **VAPT methodology** including planning, discovery, attack, and reporting phases.
6. Learned the importance of proper documentation and reporting in cybersecurity assessments.

Challenges Faced :

1. Setting up the virtual lab environment using **Oracle VM VirtualBox** required careful network configuration.
2. Initial configuration and feed synchronization of **OpenVAS** took significant time.
3. Understanding vulnerability severity scores and CVSS metrics required additional research.
4. Interpreting scan results from different security tools was initially challenging.

5. Ensuring proper communication between **Kali Linux and Metasploitable** required correct network adapter configuration.

Conclusion :

- This project demonstrated the process of performing a vulnerability assessment using open-source tools.
- By scanning the target system, several vulnerabilities were discovered and evaluated using CVSS risk scoring.
- The results highlight the importance of continuous security monitoring and vulnerability management in maintaining a secure system environment.

References :

- **OWASP Foundation.**
- **National Institute of Standards and Technology.**
- **National Vulnerability Database.**